Seguridad en Redes y Análisis Inteligente de Amenazas

Tema 9. Redes VPN y comunicaciones anónimas

Índice

Esquema

Ideas clave

9.1. Introducción y objetivos

9.2. Arquitecturas de VPN

9.3. Tecnologías para crear una VPN

9.4. Freenet

9.5. Invisible Internet Project: I2P

9.6. The Onion Router: TOR

9.7. Referencias bibliográficas

A fondo

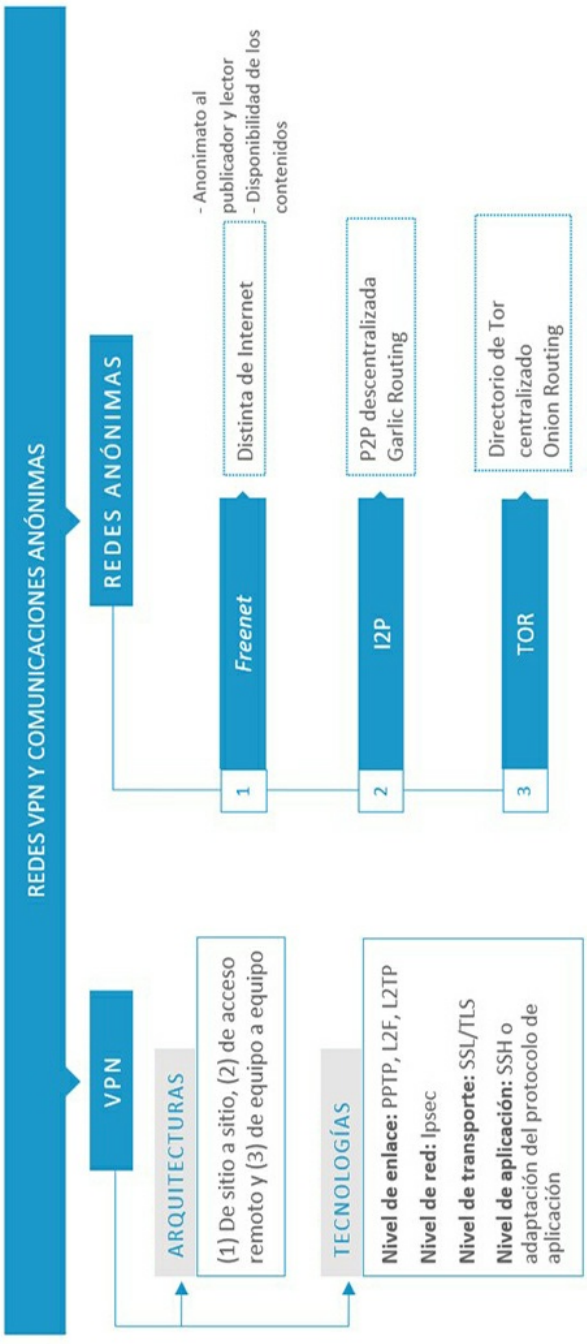
ENS. Seguridad en VPN

Guide to IPsec VPN

How Does Tor Really Work? The Definitive Visual Guide

Test

Esquema



© Universidad Internacional de La Rioja (UNIR)

9.1. Introducción y objetivos

Las **redes privadas virtuales (VPN)** son una extensión de la red local sobre una red pública o no controlada, como es el caso de Internet.

Uno de los ejemplos más conocidos de VPN es el de **conectar dos o más sucursales de una empresa,** utilizando Internet como vínculo de unión, y permitir a los trabajadores o miembros la conexión desde su casa al centro de trabajo y el acceso a recursos de la empresa como si estuviera dentro de la red local de la organización.

Para que el establecimiento de una VPN sea seguro es necesario proporcionar los siguientes servicios de seguridad: **autenticación y control de acceso del usuario,** es decir, saber quién es el usuario que accede a los recursos y qué nivel de acceso debe tener; **integridad y autenticación de los datos,** es decir, garantizar que los datos enviados/recibidos provienen de una fuente confiable y no han sido modificados; **confidencialidad de la información,** ya que se realizará una conexión a través de un medio poco seguro, los datos son susceptibles de ser interceptados por terceros, por lo que el cifrado de datos es muy recomendable; y **no repudio,** es decir, que los mensajes deben de ir firmados digitalmente, para que no se pueda negar la autoría de dichos mensajes.

Normalmente las VPN se crean haciendo uso del protocolo Ipsec, pero también pueden usarse otros protocolos como PPTP, L2F, L2TP, SSL/TLS, SSH, etc., para establecer el túnel.

Las redes VPN son una muy buena solución para aportar, como se ha comentado: confidencialidad, integridad y autenticación. Sin embargo, existen ocasiones en las que se persigue el anonimato en las comunicaciones y esta característica no se alcanza utilizando una VPN. Por ejemplo, los concentradores VPN conocen quién es

© Universidad Internacional de La Rioja (UNIR)

el otro extremo de la comunicación, así como los servidores con los que el cliente se está comunicando.

Las **motivaciones** para perseguir el anonimato pueden ser diversas (tanto de moralidad aceptable como discutible):

- Libertad de expresión.
- Acceso a servicios restringidos por nuestro gobierno.
- Acceso a o publicación de información con contenido ilegal.
- Acceso a o publicación de servicios ilegales.

Dentro de las alternativas que persiguen ofrecer anonimato a sus clientes se encuentran las siguientes: Freenet, I2P y TOR.

Los **objetivos** del tema se resumen a continuación:

- Estudiar las principales arquitecturas y tecnologías de las redes VPN.
- Saber escoger la mejor solución VPN en base a las características requeridas.
- Conocer el funcionamiento de las redes de anonimato más extendidas en la actualidad: Freenet, I2P y TOR.

© Universidad Internacional de La Rioja (UNIR)

9.2. Arquitecturas de VPN

Una red privada virtual (VPN) es una red virtual construida sobre una red física existente para proveer comunicaciones seguras que protejan la información transmitida entre redes o entre dispositivos finales (Snader, 2006). Dado que las redes VPN se pueden construir sobre redes ya existentes (como Internet), su uso está asociado a securizar la transferencia de información sensible que pasa por redes públicas. El NIST realiza una revisión de las arquitecturas de VPN en(NIST (2020) y el Esquema Nacional de Seguridad (ENS) presenta las tecnologías más utilizadas en función de la capa del modelo OSI en CCN (2017).

Desplegar una red VPN es una aproximación mucho más económica que la opción de utilizar enlaces privados entre sedes de una organización. Los enlaces privados implican un acuerdo con entidades externas (los ISP implicados) y, en la actualidad, son implementados en su mayoría configurando una VPN con el protocolo IPsec.

Adicionalmente, el uso de redes VPN es mucho más flexible y permite el acceso remoto seguro a estaciones de trabajo externas (teletrabajo), conexión entre sedes de la misma organización. Es posible establecer también una VPN dentro de la organización para proteger las comunicaciones particularmente sensibles de entidades que, aun dentro de la misma red, no deben tener acceso a la información compartida.

A continuación, se presentan las arquitecturas de VPN más utilizadas [(CCN, 2017) y (NIST, 2020)]: (1) VPN sitio a sitio, (2) VPN de acceso remoto, (3) VPN de equipo a equipo. En la siguiente sección se indicarán las tecnologías que se pueden utilizar para implementar estas arquitecturas en la práctica.

VPN de sitio a sitio

Es cada vez más común que una organización disponga de sedes en distintas partes

© Universidad Internacional de La Rioja (UNIR)

del mundo, pero requiera que los trabajadores de algunos departamentos puedan trabajar como si estuvieran en la misma red interna (respecto a su nivel de conectividad y de seguridad).

En estas situaciones es frecuente utilizar una **VPN de sitio a sitio** estableciendo una conexión VPN entre los concentradores VPN (VPN *gateways*) de cada sede (ver Figura 1) y poder así **trabajar entre sedes** como si estas estuvieran en la misma red interna.

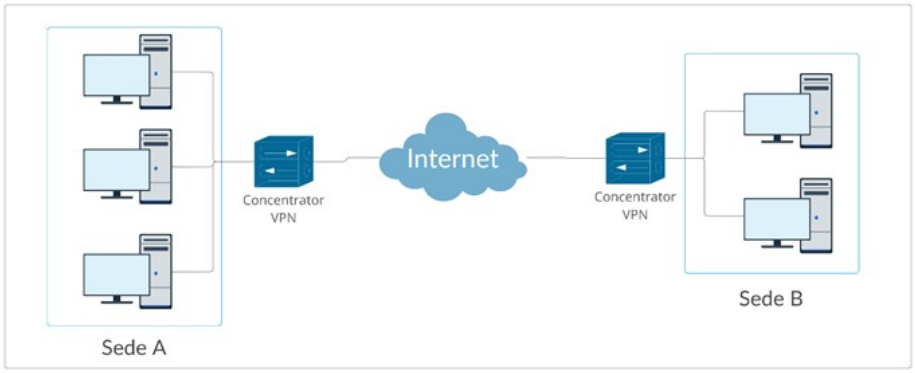


Figura 1. VPN sitio a sitio. Elaboración propia.

El enrutamiento en cada red se configura de forma que el tráfico de los equipos que deban comunicarse con la otra sede **se enrute automáticamente** a través de la conexión VPN. Así pues, los equipos cliente no deben tener instalado ningún *software* relacionado con la VPN ni cambiar de alguna forma su configuración de red; será para ellos transparente la conexión entre sedes.

Una única conexión VPN puede ser capaz de soportar todas las comunicaciones entre las dos sedes. En ciertas ocasiones, se configura más de una conexión VPN para poder aplicar distintos niveles de seguridad a cada grupo de comunicaciones (agrupadas, por ejemplo, por departamentos).

Los concentradores VPN pueden ser dispositivos dedicados o incorporar esta funcionalidad en otros dispositivos de red como un cortafuegos o un *router* (los

© Universidad Internacional de La Rioja (UNIR)

NGFW incluyen generalmente esta funcionalidad).

Ha de señalarse que este tipo de VPN **protege las comunicaciones al pasar por Internet,** pero no así dentro de las redes internas de cada sede organizacional.

VPN de acceso remoto

Un tipo de VPN cada vez más frecuente es la **VPN de acceso remoto.** Suele emplearse para **conexiones de trabajo desde el hogar** a través de la red pública. Pueden ser conexiones ocasionales o puestos de teletrabajo permanente.

Para implementar esta arquitectura, la organización despliega un concentrador VPN en su red, con el que los equipos remotos establecen una conexión VPN (ver la Figura 2). Al igual que en la arquitectura anterior, este concentrador VPN puede ser un equipo dedicado o estar integrado en otro dispositivo de red. El equipo cliente debe instalar y configurar adecuadamente algún *software* VPN que le permita conectarse con el concentrador.

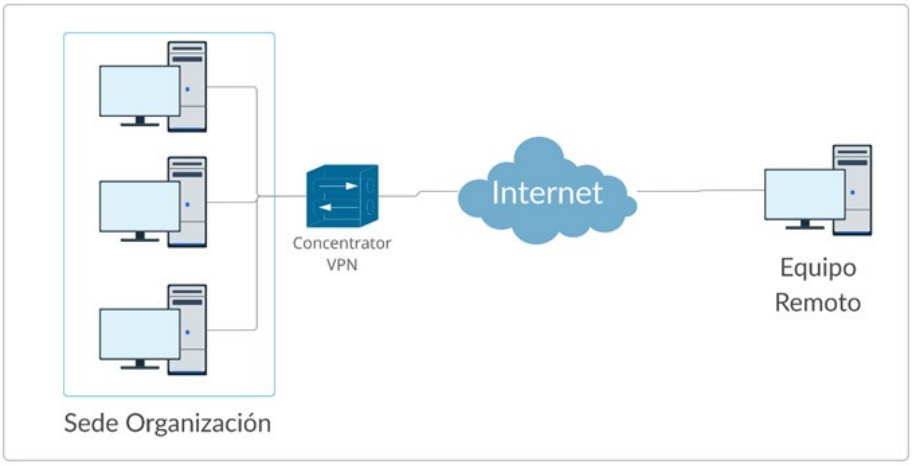


Figura 2. VPN de acceso remoto. Elaboración propia.

Algunas organizaciones utilizan en esta arquitectura un *split-tunnel* VPN para diferenciar el tráfico que el equipo cliente debe enviar por el túnel hasta la organización y el tráfico de propósito general (búsquedas en Internet) que puede salir

© Universidad Internacional de La Rioja (UNIR)

por la conexión de Internet del trabajador.

Hay que recordar que la conexión VPN **no protege la comunicación de extremo a extremo,** sino que a partir del concentrador VPN (dentro de la red interna) la comunicación sale del túnel, pudiendo así viajar sin protección en ese tramo de red.

VPN de equipo a equipo

La arquitectura **VPN de equipo a equipo** se utiliza para realizar conexiones seguras entre dos equipos finales. Generalmente, se usa para realizar tareas de **administración remota de servidores**. Si solo se permite configurar estos servidores utilizando una VPN, un posible atacante deberá primero descubrir las credenciales de la VPN para, posteriormente, intentar vulnerar el servidor en cuestión. Esta arquitectura protege también frente a acciones como el escaneo de puertos o los ataques de diccionario, ya que el servicio final no puede ser accedido a menos que se haya realizado con éxito la conexión VPN.

La conexión VPN se realiza entre el equipo origen (equipo remoto) y el servidor (ver la Figura 3). En este caso, la organización configura el servidor para ofrecer servicios VPN por medio de *software* específico y los equipos remotos que deban realizar las tareas de administración. Los usuarios de los equipos remotos utilizarán el cliente VPN de sus equipos para establecer una conexión VPN con el servidor cuando deban realizar tareas de administración.

© Universidad Internacional de La Rioja (UNIR)

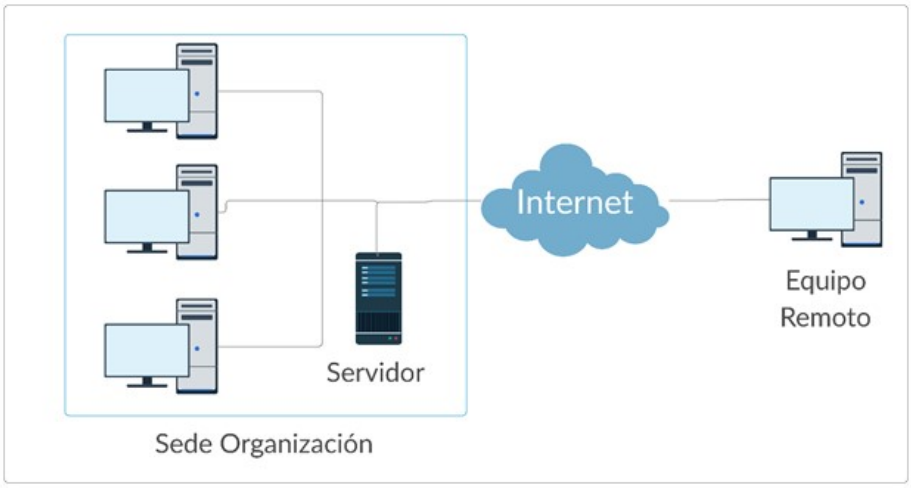


Figura 3. VPN de equipo a equipo. Elaboración propia.

Así pues, en esta arquitectura de red **sí se protege toda la comunicación de extremo a extremo,** ya que el túnel abarca tanto el origen como el destino de esta.

© Universidad Internacional de La Rioja (UNIR)

9.3. Tecnologías para crear una VPN

Existen distintos protocolos con los que se pueden proveer las características que definen a una VPN. La decisión de cuál aplicar depende de la capa en la que se quiera implementar la VPN: nivel de enlace, de red, de transporte o de aplicación (ver la Figura 4).

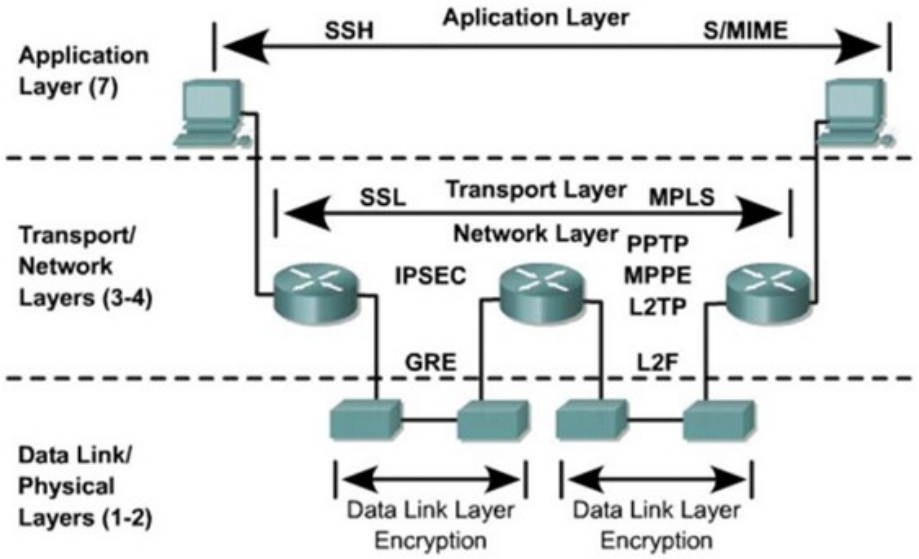


Figura 4. Protocolos para implementar una VPN agrupados por capas del modelo OSI. Fuente: CISCO (2006).

VPN de nivel de enlace

Las redes VPN de nivel de enlace se implementan para proteger enlaces físicos específicos. Por ejemplo, la conexión entre dos departamentos en pisos o edificios diferentes. Se ha de tener en cuenta que estas VPN protegen el nivel de enlace y superiores, pero solo protegen el enlace en el que son implementadas y no la comunicación de extremo a extremo.

Este tipo de redes VPN se encuentran bajo la capa IP, por lo que pueden ser utilizadas con cualquier protocolo de red, el resto de VPN que funcionan en capas

© Universidad Internacional de La Rioja (UNIR)

superiores se basarán siempre en un protocolo concreto de red, concretamente en el protocolo IP.

Se implementan mayoritariamente sobre el protocolo PPP (*Point-to-Point Protocol*, RFC 1661), añadiendo mecanismos de seguridad sobre este para implementar las características fundamentales de toda VPN. Como puede verse en la Figura 4, PPP actúa a nivel de enlace, pero los protocolos que se utilizarán para añadir a este las características de VPN operan en capas superiores. Los principales protocolos sobre los que se han implementado las VPN de nivel de enlace son: PPTP, L2TP y L2F.

PPTP (*Point-to-Point Tunneling Protocol*)

Permite crear un túnel sobre PPP entre el cliente y el concentrador VPN de la organización. Ambos extremos han de tener instalado y configurado el *software* de PPTP. La creación del túnel se realiza mediante el protocolo GRE (*Generic Routing Encapsulation*, RFC 2784) que encapsula los datos.

Ha sido un protocolo ampliamente utilizado para crear VPN de nivel de enlace, fundamentalmente por su facilidad de configuración en servidores Microsoft. De hecho, Microsoft creó su propio mecanismo de cifrado (MPPE, *Microsoft Point-to-Point Encryption*) sobre PPP para usarlo en PPTP y también utiliza una autenticación más robusta que la ofrecida por PPP, MS-CHAP, aunque actualmente presenta numerosas vulnerabilidades conocidas.

Actualmente, como consecuencia de las vulnerabilidades conocidas en los mecanismos de autenticación (no solo CHAP y PAP sino también MS-CHAP) y de cifrado de PPP, se considera que PPTP **no es un protocolo seguro y se desaconseja su uso.**

L2F (Layer 2 Forwarding)

Con L2F se puede crear un túnel entre el ISP y el concentrador VPN de la

© Universidad Internacional de La Rioja (UNIR)

organización, solo permite crear túneles entre dispositivos de red (no entre dispositivos finales). Por este motivo, la conexión desde el cliente remoto y el ISP viaja sin proteger. Como el túnel se establece desde el ISP, es necesario que este ofrezca estos servicios al cliente remoto, con los consecuentes inconvenientes asociados a la dependencia de una entidad externa.

L2TP (Layer 2 Tunneling Protocol)

A raíz de L2F de Cisco y el PPTP de Microsoft, surge L2TP, que es el más avanzado de estos. Con L2TP es posible establecer un túnel entre cliente remoto y concentrador VPN de la organización, ambos extremos deberán tener instalado y configurado el *software* de L2TP.

En cuestiones de autenticación añade a los propios de PPP (PAP y CHAP): RADIUS y TACACS+. Respecto a la confidencialidad es posible combinar L2TP con IPsec para aplicar un cifrado robusto a la comunicación.

En resumen, a nivel de enlace:

- PPTP presenta vulnerabilidades conocidas y, por lo tanto, graves problemas de seguridad.
- Con L2F solo se protege una parte de la comunicación y es necesario que intervenga una tercera parte (el ISP debe ofrecer este servicio).
- L2TP combina las mejores características de PPTP y L2F, pudiéndose utilizar en cualquier situación en la que se usaría PPTP y L2F. Puede utilizar los mismos mecanismos de autenticación y añade el uso recomendado de IPsec para el cifrado de sus comunicaciones.

VPN de nivel de red

Al actuar a nivel de red, este tipo de VPN puede proteger la carga útil de IP (de la capa de transporte hacia arriba) y algunas partes de la cabecera IP. Funciona

© Universidad Internacional de La Rioja (UNIR)

únicamente con base en paquetes IP.

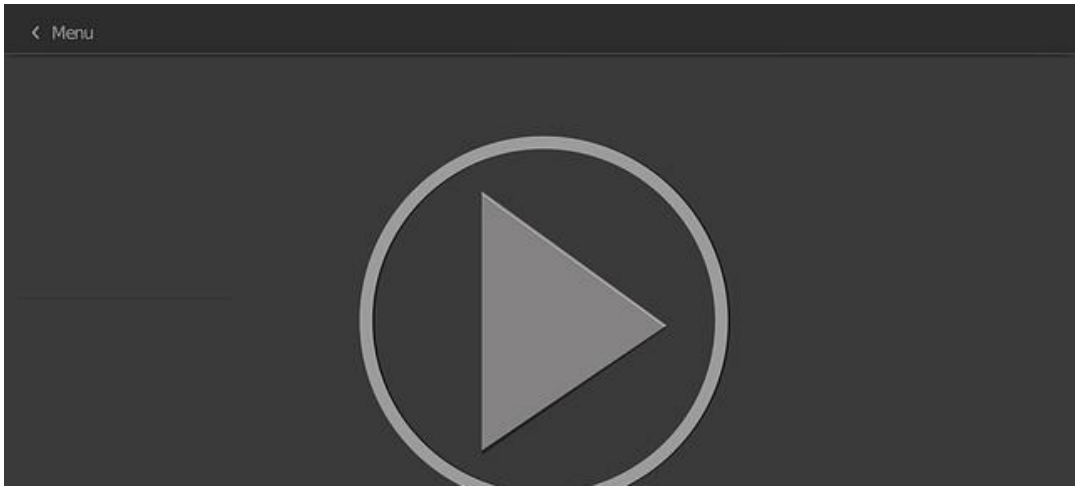
Se implementan utilizando el estándar IPsec (ver los detalles de este protocolo en el t e m a *Protocolos de seguridad*). Los protocolos fundamentales de IPsec: *Authentication Header* (AH, RFC 4302), *Encapsulating Security Payload* (ESP, RFC 4303) e *Internet Key Exchange v2* (IKEv2, RFC 5996).

Presenta dos **modos de operación:**

- **Modo túnel:** utilizado para implementar VPN de sitio a sitio y de acceso remoto.
- **Modo transporte:** utilizado para la implementación de VPN de equipo a equipo.

E l **inconveniente** relacionado con las VPN de IPsec es que su configuración requiere un elevado nivel de conocimiento del estándar IPsec. Dada la importancia de este tipo de redes VPN, son la recomendación número uno siempre que la solución VPN buscada permita su uso. El NIST ha preparado un documento que las detalla en profundidad (NIST, 2020).

En el vídeo, *Redes VPN utilizando Ipsec,* se muestra un ejemplo de configuración de una red VPN utilizando IPsec en un *router* Mikrotik y se revisan los protocolos utilizados en el estándar IPsec para establecer este túnel.



© Universidad Internacional de La Rioja (UNIR)



Accede al vídeo:

https://unir.cloud.panopto.eu/Panopto/Pages/Embed.aspx?id=eed7a945-6522-4a61-81c3-af63012dabed

VPN de nivel de transporte

Las VPN de transporte se suelen implementar utilizando el protocolo SSL/TLS (ver los detalles de este protocolo en el tema *Protocolos de seguridad*). Una ventaja asociada a esta capa es que son transparentes a cualquier aplicación, por tanto, no requieren que la capa de aplicación se modifique en forma alguna. El protocolo SSL/TLS permite tanto la autenticación de cliente como la autenticación del servidor, aunque la mayoría de las implementaciones solo utilizan la autenticación del servidor. El cliente se autentica posteriormente con usuario y contraseña en el portal Web presentado.

Las redes VPN de nivel de transporte se emplean generalmente en las arquitecturas **VPN de acceso remoto,** en las que un cliente remoto quiere utilizar una o varias aplicaciones de la red interna de la organización basadas en Web (o que serán adaptadas a un entorno Web). Otra gran ventaja de este tipo de redes VPN es que al basarse en Web el cliente no ha de instalar *software* adicional, y podrá utilizar su navegador Web.

El tipo de VPN de SSL/TLS más usual se basa en un portal Web instalado en el servidor VPN, por medio del cual los usuarios con una autenticación exitosa podrán acceder a las aplicaciones internas asociadas a este portal. Por ejemplo, en la Figura 5 se muestra el portal Web asociado a un concentrador VPN de Check Point en el

© Universidad Internacional de La Rioja (UNIR)

que se puede acceder a recursos de la red interna y se puede navegar utilizando una IP de la red organizacional.

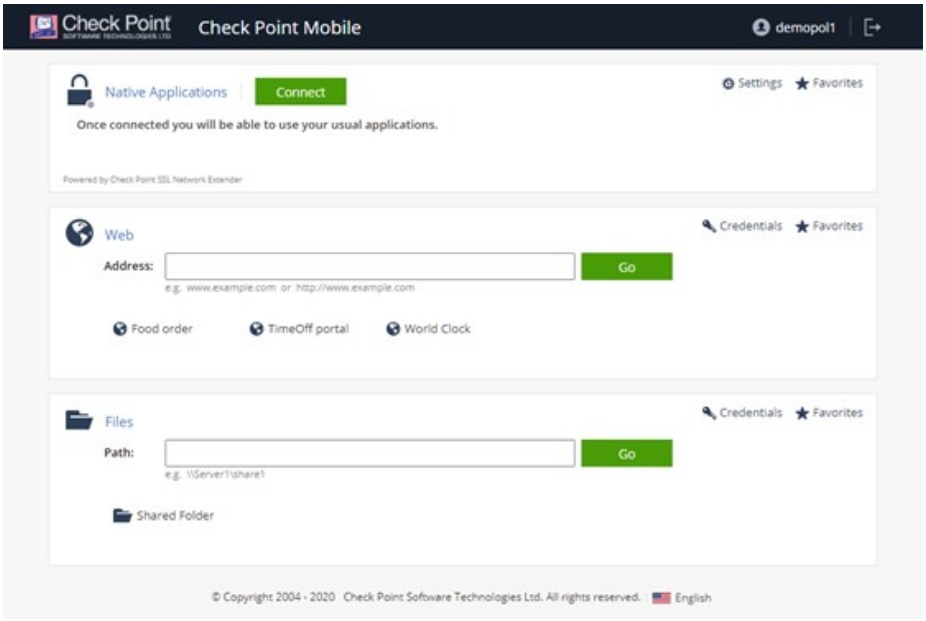


Figura 5. Ejemplo VPN de portal Web de Check Point. Fuente: CheckPoint [web].

https://www.checkpoint.com/es/quantum/remote-access-vpn/

Otra función común de este tipo de redes es utilizar un *proxy,* que será el que se conectará por medio de HTTPS a los servidores web finales. El cliente se autentica en el portal Web de la VPN y tras esto será el *proxy* el que establezca la conexión con el servidor destino.

Para comunicarse con aplicaciones que no estén adaptadas a la Web, será necesario que el cliente instale un *software* específico a través del que tunelizar la conexión a la aplicación, generalmente sobre HTTPS.

VPN de nivel de aplicación

A nivel de aplicación la implementación de una VPN pasa por (1) modificar la aplicación con la que se quiere conectar o (2) utilizar un protocolo de nivel de aplicación por el que tunelizar la comunicación con la aplicación final.

© Universidad Internacional de La Rioja (UNIR)

La primera opción no siempre es posible, ya que en muchas ocasiones se utilizan aplicaciones privativas o no se poseen los recursos necesarios para desarrollar una modificación específica de la aplicación (incluso si esta es de código libre o propiedad de la organización).

En cuanto a la segunda opción, la aproximación más frecuente es utilizar el protocolo SSH (*Secure Shell*, RFC 4253). Este protocolo de nivel de aplicación permite acceder de forma segura a una terminal remota de los servidores o equipos finales que tengan instalado el *software* de servidor de SSH. Es posible establecer un túnel seguro desde el equipo cliente de SSH hasta el servidor SSH. Estas redes VPN se utilizan generalmente por parte de los administradores IT, ya que suponen una configuración costosa por cada cliente.

Como ejemplo se puede realizar una redirección local (*local forwarding*) con SSH utilizando el siguiente comando:

ssh -L <PuertoLocal>:<EquipoRemoto>:<PuertoRemoto> usuario@<EquipoRemoto>

Este comando enlaza el puerto local escogido con un puerto del servidor remoto. Todas las conexiones a nuestro puerto local serán tunelizadas por SSH y dirigidas al servidor remoto y el puerto remoto escogido. Esta función podría utilizarse para conectarse a la base de datos de la red interna de nuestra organización, configurada para permitir conexiones desde nuestro servidor SSH.

© Universidad Internacional de La Rioja (UNIR)

9.4. Freenet

Freenet es un sistema basado en una red P2P para la publicación, replicación y recuperación de información con el fin de **proteger la identidad de lectores y autores a través del anonimato.**

Su desarrollo lo inició Ian Clarke en 1999 en su trabajo fin de grado (Clarke et al., 2001), con la idea de proveer un sistema capaz de luchar contra la censura en Internet. Desafortunadamente, esto conllevaría que también se utilizara para almacenar contenido ilegal, como se indica en la propia aplicación. Esta red provee, por tanto, anonimato a lectores y autores y garantiza la disponibilidad de los recursos. Los clientes almacenan información en su equipo a la que no son capaces de acceder directamente al estar cifrada.

Freenet fue ideado para proveer las **siguientes características** (Muoh, 2006):

- Seguridad.
- Anonimato para publicador y consumidor de contenido.
- Almacenamiento de información sin implicaciones para el usuario que lo almacena.
- Redundancia de información para proveer disponibilidad y eficiencia.

La tecnología de Freenet se basa en una **red P2P completamente descentralizada** en la que los nodos aportan parte de su almacenamiento en disco sin utilizar para almacenar archivos de la red y cooperan para enrutar solicitudes y respuestas propias de la red. Una parte importante que hace que se cumpla la tercera de las características anteriores es que los usuarios de la red desconocen los archivos almacenados en su disco (están cifrados con una contraseña que no poseen).

Se utilizan tres **métodos para generar claves** para los archivos almacenados en la

© Universidad Internacional de La Rioja (UNIR)

red:

- ***Keyword Signed Keys (KSK).*** Esta clave se deriva del nombre descriptivo del archivo con el que se genera un par de clave pública y privada. A la clave pública se le calcula un *hash* que hará las veces de clave del archivo, y con la clave privada se firma el archivo para verificar su autenticidad una vez sea descargado.

- ***Self Signed Keys (SSK).*** Los publicadores de la red Freenet pueden generar un espacio de nombres (*namespace*) de claves para los archivos que quieren publicar en la red. La SSK es una pareja de claves pública y privada. Solo el poseedor de la privada puede insertar archivos en la red asociados a ese *namespace*.

- ***Content Signed Keys (CSK).*** Estas claves son obtenidas como un *hash* de los archivos antes de ser insertados en la red. La clave generada se utiliza para cifrar el archivo que posteriormente se almacena en la red.

A continuación, se muestra un ejemplo de una **ruta a un fichero en Freenet.** Primero siempre se especifica el protocolo freenet, las siguientes tres letras indican el método con el que se ha generado la clave (en este caso KSK) y tras la @ el texto descriptivo de los archivos.

```
freenet:KSK@text/philosophy/sun-tzu/art-of-war.doc
```

Un usuario que quiera recuperar un fichero de Freenet debe conseguir generalmente el *namespace*, el CHK y la clave de descifrado. Una vez recuperado el fichero desde alguno de los nodos que lo almacenan, se descifra el fichero y se verifica su firma utilizando las claves correspondientes.

El proceso de **búsqueda en Freenet** solo permite búsquedas exactas, utilizando las claves de los archivos. Como se observa en la Figura 6, las solicitudes se dirigen sucesivamente a los nodos vecinos (*Data Request*) hasta que por una de las rutas se alcanza el nodo que almacena el archivo recibiendo un *Data Reply* que se propaga

© Universidad Internacional de La Rioja (UNIR)

hasta el origen de la búsqueda. En caso de que se exceda el TTL asociado a la búsqueda, se respondería con un *Reply Not Found*.

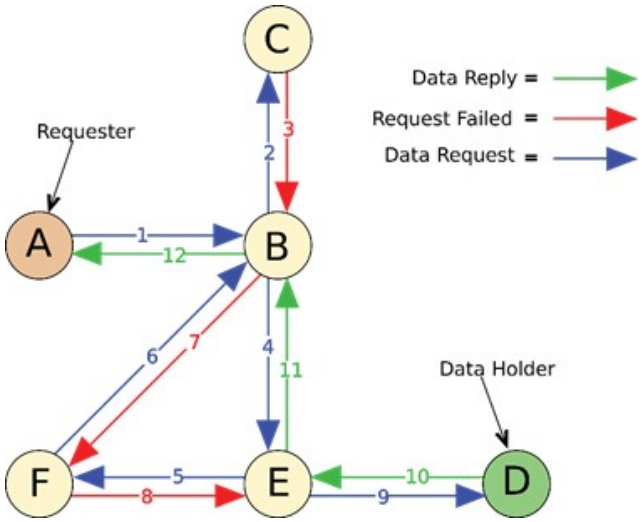


Figura 7. Esquema del intercambio de una solicitud y respuesta en la red Freenet. Fuente: Wikipedia [web]. https://en.wikipedia.org/wiki/Freenet#/media/File:Freenet_Request_Sequence_ZP.svg

© Universidad Internacional de La Rioja (UNIR)

9.5. Invisible Internet Project: I2P

El proyecto invisible de Internet (I2P) es una **red de anonimato basada en Mix Network** al igual que Tor. I2P fue diseñada para que tanto cliente como servidor no sean capaces de identificarse entre sí (y tampoco por terceras partes).

En cuestiones de **material criptográfico en I2P** se utiliza:

- Cifrado asimétrico con ElGamal de 2048 bits. Fundamentalmente para cifrar las claves AES con las que se cifrarán los datos.
- Cifrado AES de 256 bits modo CBC para dotar de confidencialidad a la información enviada.
- SHA-256 como función *hash*. Para garantizar la integridad de los datos enviados.
- Firma con DSA (actualmente DSA de curva elíptica ECDSA). Para firmar la información que se incluye en la netDB (información sobre el contacto de un *router* o de una dirección .i2p)

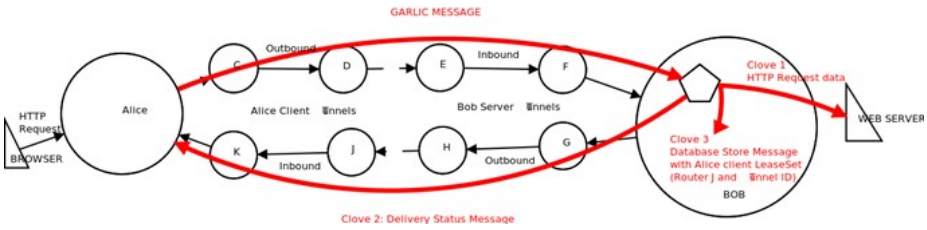


Figura 8. Esquema del funcionamiento de Garlic Routing de I2P. Fuente: I2P. [web] Garlic Routing y terminología «Garlic». https://geti2p.net/es/docs/how/garlic-routing

A diferencia de Tor, utiliza el concepto de ***garlic routing*** que sus creadores consideran como una evolución al *onion routing* de Tor. En I2P los túneles son unidireccionales. Cada parte construye dos túneles, uno para el tráfico de salida y otro para el de entrada. Por lo tanto, se necesitan cuatro túneles para una vuelta

© Universidad Internacional de La Rioja (UNIR)

completa de un mensaje y su respuesta (ver la Figura 8). Los mensajes son dientes de un ajo que se agrupan para ser enviados conjuntamente por el túnel *outbound*.

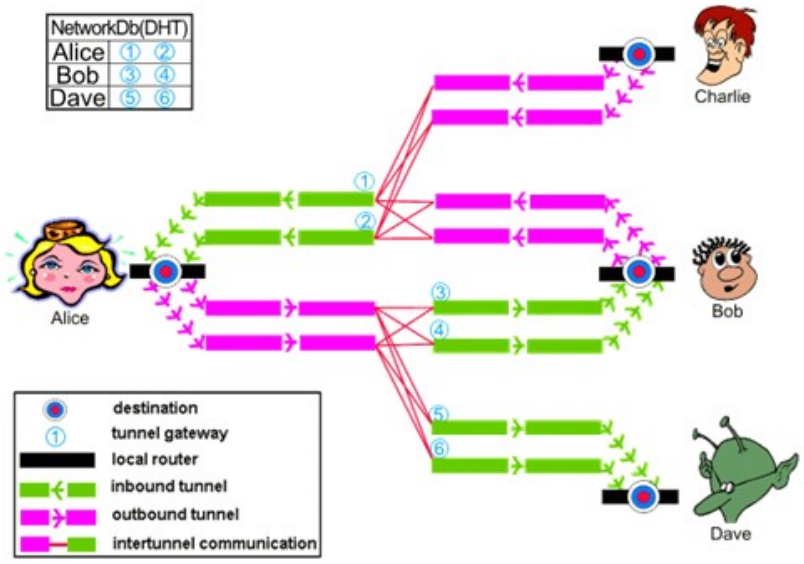


Figura 9. Esquema de funcionamiento de los túneles y la DHT en I2P. Fuente: I2P [web].

https://geti2p.net/es/docs/how/intro

Como se puede observar en la Figura 9, Alice, Bob, Charlie y Dave implementan un *router* local (línea negra en la leyenda). Los túneles entrantes o *inbound* (línea verde en la leyenda) se han numerado del 1 al 6. Por claridad, se omiten algunos túneles de salida y de entrada en la imagen.

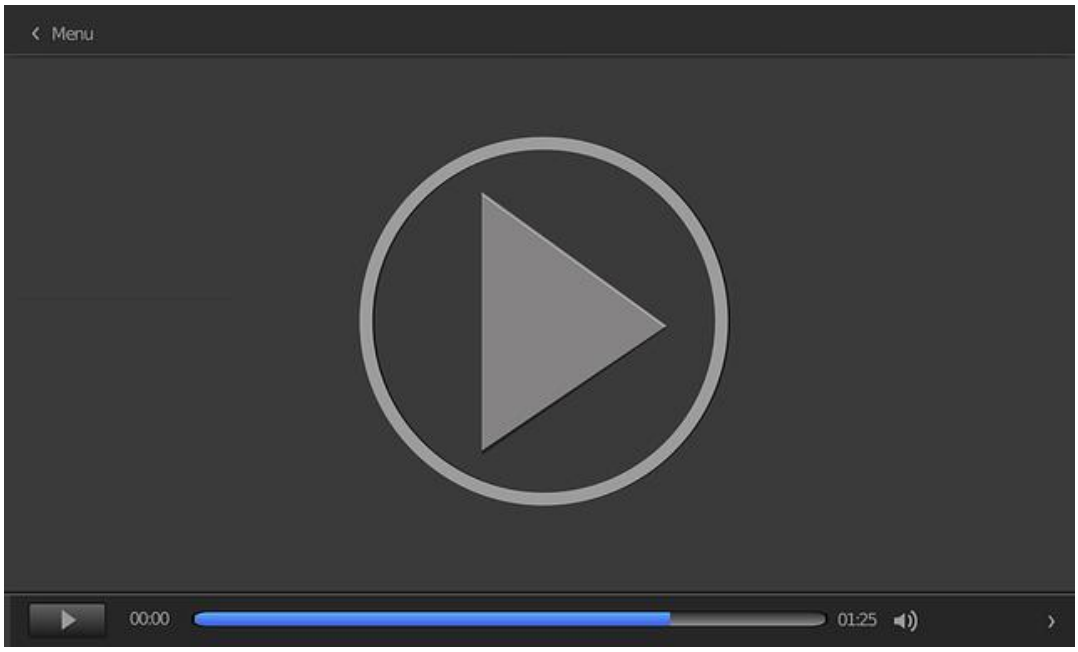
I2P tiene su propia **base de datos de red distribuida** usando una tabla de *hash* distribuida o DHT (utilizando una modificación del algoritmo Kademlia) para almacenar y consultar información de rutas y contactos de forma segura. Así, Alice puede consultar en la DHT que túneles de entrada son los asociados a Bob (3 y 4 según la Figura 9) y envía un mensaje por uno de sus túneles de salida (rosa) en dirección a uno de los túneles entrantes (verde) de Bob (túnel 3 o 4). Bob seguiría el mismo proceso que Alice para responder a este mensaje.

© Universidad Internacional de La Rioja (UNIR)

9.6. The Onion Router: TOR

TOR es la red de anonimato más extendida en la actualidad. Es una red que funciona sobre Internet, en la que se persigue el anonimato y la privacidad de los datos. Los dominios de esta red tienen una extensión .onion y solo pueden consultarse estando conectados a ella.

En el vídeo, *Despliegue de un servicio oculto en la red TOR*, se presenta el proceso para desplegar un servicio oculto en la red TOR, revisando algunas de las características más importantes de esta.



Accede al vídeo:

https://unir.cloud.panopto.eu/Panopto/Pages/Embed.aspx?id=8b72710e-3fa3-4e19-9bde-af63012db7d5

© Universidad Internacional de La Rioja (UNIR)

En primer lugar, un cliente Tor (Alice) consulta al directorio de Tor centralizado que le ofrece la información (de conexión y la clave pública asociada) de 3 nodos de la red que harán las veces de *entry guard*, *middle relay* y *exit relay*. Alice acordará una clave simétrica con cada uno de estos 3 nodos utilizando las claves públicas que recibió del directorio de Tor. De esta forma, consigue las claves simétricas compartidas azul, verde y roja (ver Figura 10).

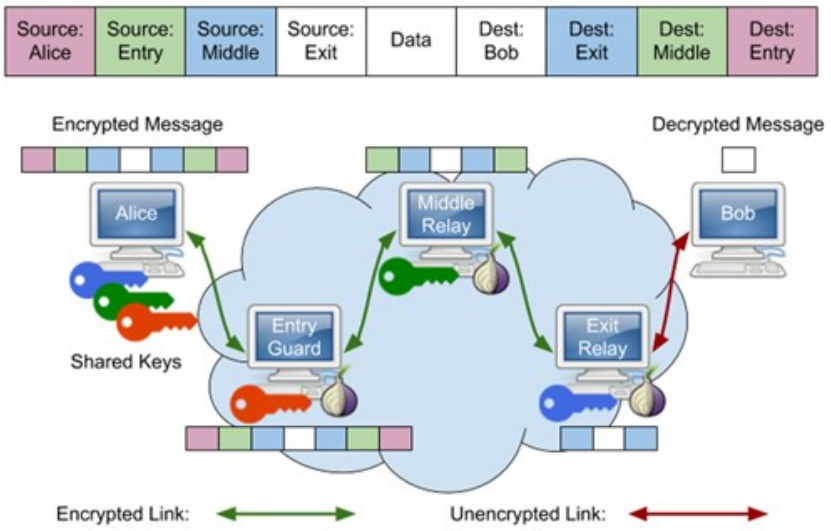


Figura 10. Esquema del funcionamiento de Onion Routing de TOR. Fuente: Goldberg, L. (Apr 4, 2020). *Tor: Anonymity For Better or For Worse.* Systems and Network Security [web]. https://medium.com/systems-and-network-security/tor-anonymity-for-better-or-for-worse-d8407b1d9287

Para comunicarse con Bob, Alice construye un mensaje por capas sucesivas de cifrado, de forma que cada nodo de la comunicación solo conoce el salto previo y el siguiente, conservando de esta forma el anonimato de la comunicación. Este mecanismo es la parte esencial del funcionamiento de **Onion Routing.**

Así pues, utilizando Onion Routing los nodos de entrada (*entry guard*) son capaces de conocer la IP origen real del cliente, no así el servicio que este está consultando. Para romper el anonimato una misma entidad ha de ser tanto el *entry guard* como el *exit relay.*

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

© Universidad Internacional de La Rioja (UNIR)

9.7. Referencias bibliográficas

CCN. (2017). *ENS. Seguridad en VPN* (Guía de Seguridad de las TIC CCN-STIC 8 3 6) . https://www.ccn-cert.cni.es/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/2299-ccn-stic-836-seguridad-en-vpn-en-el-marco-del-ens/file.html

CISCO. (2006). *Module 3 VPN and Encryption* (Network Security 2). https://slidetodoc.com/network-security-2-module-3-vpn-and-encryption/

Clarke I., Sandberg O., Wiley B., y Hong TW. (2001) Freenet: un sistema de recuperación y almacenamiento de información anónimo distribuido. En: Federrath H. (eds.) Diseño de tecnologías de mejora de la privacidad. *Lecture Notes in Computer Science, vol 2009.* Heidelberg. https://doi.org/10.1007/3-540-44702-4_4

Muoh, C. (2006). *A Tutorial on Bittorrent, Freenet and Gnutella Protocols* (Technical Department of Computer Science, Kent State University). http://medianet.kent.edu/surveys/IAD06S-P2PArchitectures-chibuike/P2P%20App.%20Survey%20Paper.htm

NIST. (2020). *Guide to IPsec VPNs (SP 800-77 Rev. 1).* National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-77r1

Snader, J. C. (2006). *VPNs illustrated: Tunnels, VPNs, and IPsec*. Addison-Wesley.

© Universidad Internacional de La Rioja (UNIR)

ENS. Seguridad en VPN

CCN (2017). ENS. Seguridad en VPN. Guía de Seguridad de las TIC. CCN-STIC 836. https://www.ccn-cert.cni.es/pdf/guias/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/2299-ccn-stic-836-seguridad-en-vpn-en-el-marco-del-ens/file.html

Guía de seguridad del Centro Criptológico Nacional (CCN-STIC 836) que presenta las distintas implementaciones de VPN junto a sus tecnologías. De especial interés el proceso de planificación y despliegue de VPN descrito en el capítulo 6.

© Universidad Internacional de La Rioja (UNIR)

Guide to IPsec VPN

Barker, E., Dand, Q, Frankel, S., Scarfone, K., y Wouters, P. NIST (2020). Guide to IPsec VPNs. *National Institute of Standards and Technology.* SP 800-77 Rev. 1. https://doi.org/10.6028/NIST.SP.800-77r1

Guía del National Institute of Standards and Technology (NIST) para implementar VPN utilizando el estándar IPsec. La explicación de los protocolos que participan en IPsec es muy detallada y clara y el apartado de casos de estudio tiene una aplicación práctica directa.

© Universidad Internacional de La Rioja (UNIR)

How Does Tor Really Work? The Definitive Visual Guide

Skerritt.blog [blog]. *How Does Tor Really Work? The Definitive Visual Guide (2020*). https://skerritt.blog/how-does-tor-really-work/

Artículo de divulgación que repasa el funcionamiento de TOR en detalle. Los ejemplos que presentan son muy clarificadores y visuales.

© Universidad Internacional de La Rioja (UNIR)

Test

1. Para establecer una arquitectura VPN:

A. Es necesario utilizar al menos un concentrador VPN.

B. Se han de cumplir bien las especificaciones del NIST o bien las del ENS.

C. Se debe configurar un enlace privado acordándolo con el ISP local.

D. Ninguna de las anteriores es correcta.

2. Una organización posee tres sedes en distintas localizaciones geográficas y quiere trabajar como si todas ellas formaran parte de la misma red local:

A. La arquitectura VPN ideal para esta situación es una VPN de sitio a sitio.

B. Debería utilizar Freenet o I2P para esto, nunca Tor.

C. La arquitectura ideal en esta situación sería una VPN de acceso remoto.

D. El protocolo más seguro para desplegar la VPN debería ser SSH.

3. Se quiere desplegar una VPN de nivel de enlace, el protocolo a utilizar debería ser:

A. SSH.

B. PPTP.

C. L2F.

D. L2TP.

4. ¿Qué protocolo se podría utilizar para desplegar una VPN de equipo a equipo?

A. IPsec.

B. SSH.

C. SSL/TLS.

D. Todas las anteriores son correctas.

© Universidad Internacional de La Rioja (UNIR)

5. El protocolo más común para implementar redes VPN de nivel de aplicación es:

A. IPsec.

B. SSH.

C. SSL/TLS.

D. L2TP.

6. Una persona teme que sus comentarios en redes sociales puedan ser utilizados en su contra por el gobierno totalitario en el que se encuentra. Para estar segura, ¿qué debería utilizar al publicar en redes?

A. Una VPN.

B. La red Freenet.

C. La red TOR.

D. Las respuestas B y C son correctas.

7. Para encontrar un recurso en Freenet:

A. Se consulta un directorio centralizado en el que se almacenan.

B. Se envía un mensaje de búsqueda a la red hasta que se encuentra el nodo que lo tiene almacenado en su disco.

C. Basta con hacer una consulta local, ya que se almacena en nuestro disco.

D. Ninguna respuesta es correcta.

8. Para comunicarnos con un nodo de la red I2P:

A. Solicitamos su información a un directorio centralizado.

B. Enviamos una consulta a una tabla de *hash* distribuidos DHT.

C. Basta con conocer su IP.

D. Debemos conocer sus túneles de salida para enviar a ellos la petición.

© Universidad Internacional de La Rioja (UNIR)

9. Para conectarnos con la red TOR:

A. Solicitamos la información necesaria a un directorio centralizado.

B. Enviamos una consulta a una tabla de *hash* distribuidos DHT para descubrir los tres *routers* con los que nos debemos comunicar.

C. Enviamos un mensaje a nuestros vecinos para descubrir los *routers* intermedios.

D. Ninguna respuesta es correcta.

10. En Onion Routing:

A. Se utilizan las claves públicas de los tres *routers* por los que pasa nuestro mensaje para cifrar en capas el mensaje enviado.

B. Se acuerdan claves simétricas con cada *router* intermedio.

C. El cliente puede escoger los *routers* por los que quiere que viaje su comunicación.

D. El servidor final conocerá la IP del cliente que le envía la consulta.

© Universidad Internacional de La Rioja (UNIR)